

MARKELO

API Security & Validation Testing Report

Practical security and invalid-request testing of the Markelo backend APIs

Prepared by	Daniel Opeyemi Olutoyinbo
Role	Cybersecurity Intern
Environment	Local / Test Environment
Testing Tool	Postman
Test Scope	Authentication, authorization, validation and error handling
Test Cases	API-001 through API-022

Confidentiality note: Testing was performed using dedicated test accounts and test data. No production credentials or production data were intentionally used.

1. Executive Summary

This report documents practical security and validation testing performed against the Markelo backend APIs. The assessment focused on authentication behavior, authorization controls, input validation, account-enumeration resistance, malformed requests, unexpected fields and selected HTTP method handling.

Overall assessment: No confirmed security vulnerabilities were identified within the tested scope. The authentication and authorization controls tested behaved as expected, and the password-reset flow demonstrated appropriate resistance to account enumeration.

22	20	1	1
Test cases	Clear passes	Environment issue	Informational observation

Key outcome

The only operational issue observed was API-008: a valid password-reset request produced HTTP 500 because the local SMTP connection was refused. This was treated as an environment/configuration issue rather than a confirmed security vulnerability. API-017 returned HTTP 405 for the individual staff-user GET endpoint and was recorded as an informational observation requiring confirmation of the endpoint's intended supported methods.

2. Objective and Scope

The objective was to perform practical API testing requested by the Markelo cybersecurity task: test basic security issues, test how the APIs handle invalid requests, document expected versus actual behavior, and recommend remediation where an issue is found.

Area	Testing performed
Authentication	Valid login, incorrect credentials, nonexistent account, missing fields, malformed email, null values
Password reset	Existing account, nonexistent account, missing email, malformed email, SMTP failure behavior
Authorization	Unauthenticated and authenticated access to roles and staff-user endpoints
Input validation	Malformed JSON and unexpected/extra request fields
HTTP methods	Selected unsupported/destructive method behavior and individual resource endpoint behavior

3. Test Environment & Method

Testing was performed against the locally hosted Django backend using Postman. The test environment included a dedicated active staff test account and locally configured test data. Requests were made only against the local/test environment.

Component	Value
Application	Markelo Django backend
Base URL	http://127.0.0.1:8000/

Component	Value
API prefix	/api/v1/
Primary tool	Postman Desktop
Authentication tested	Django session-based login
Test data	Dedicated test account / local test data

4. Detailed Test Results

ID	Test case	Expected result	Actual result	Status
API-001	Valid login with active test account	200 + user data	200	PASS
API-002	Login with incorrect password	Authentication rejected	403	PASS
API-003	Login with non-existent account	Authentication rejected without account enumeration	403	PASS
API-004	Login with missing password	400 validation error	400	PASS
API-005	Login with missing email	400 validation error	400	PASS
API-006	Login with malformed email (not-an-email)	400 validation error	400	PASS
API-007	Login with invalid email format (teststaff)	400 validation error	400	PASS
API-008	Password reset with existing active account	202	500 — SMTP connection refused	ENVIRONMENT ISSUE
API-009	Password reset with non-existent account	Generic 202 without account enumeration	202	PASS
API-010	Password reset with missing email	400	400	PASS
API-011	Password reset with malformed email	400	400	PASS
API-012	Unauthenticated access to /roles/	Access denied	403	PASS
API-013	Unauthenticated access to /staff-users/	Access denied	403	PASS
API-014	Unauthenticated access to /staff-users/1/	Access denied	403	PASS
API-015	Login with valid active test account for authenticated testing	200 + session	200	PASS
API-016	Authenticated access to /staff-users/	200 + staff-user data	200	PASS
API-017	GET individual staff-user endpoint	Respond according to supported method	405	OBSERVATION
API-018	Unauthenticated DELETE /staff-users/	Request rejected	403	PASS
API-019	Authenticated access to /roles/	200 + roles data	200	PASS
API-020	Malformed JSON on login	400	400	PASS
API-021	Unexpected/extra field on login	Request rejected	400	PASS
API-022	Null email/password	Authentication rejected	403	PASS

Interpretation note: API-018 returned 403 because the request was unauthenticated. This demonstrates authorization rejection, but does not independently establish that DELETE is an unsupported method. API-017 is therefore retained as an observation rather than a vulnerability.

5. Findings & Remediation

Finding 1 — API-008: Password Reset SMTP Failure

Classification	Operational / environment issue
Observed behavior	A valid password-reset request returned HTTP 500 because the local SMTP connection was refused.
Security impact	No confirmed exploitable security vulnerability. If similar failures exposed detailed errors in a production environment, they could disclose implementation details and degrade service reliability.
Recommended remediation	Verify SMTP configuration and connectivity; handle email-service failures gracefully; log detailed failures internally; return a controlled generic response to clients; ensure DEBUG is disabled in production.

Finding 2 — API-017: Individual Staff-User Endpoint Returns 405

Classification	Informational observation
Observed behavior	GET requests to the individual staff-user endpoint returned HTTP 405 Method Not Allowed.
Security impact	No security impact was established from this behavior.
Recommended remediation	Confirm the intended supported HTTP methods for /staff-users// and document or implement them consistently with the API contract.

6. Security Controls That Passed

- Credential failures were rejected without revealing whether the account exists.
- Malformed email input was rejected with HTTP 400 validation responses.
- Missing required login fields were rejected.
- Unauthenticated requests to protected roles and staff-user endpoints were rejected with HTTP 403.
- Authenticated access to tested protected endpoints succeeded.
- Password-reset requests for nonexistent accounts returned the same generic acceptance response as intended, supporting account-enumeration resistance.
- Malformed JSON and unexpected request fields were rejected.

7. Overall Assessment

Within the scope of the 22 test cases executed, the Markelo APIs demonstrated generally appropriate behavior for the tested authentication, authorization and input-validation scenarios. No confirmed security vulnerability was identified.

The password-reset SMTP failure should be addressed before relying on the password-reset flow in an environment where the email service is expected to be available. The individual staff-user 405 response should also be checked against the intended API contract.

8. Recommended Next Actions

1. Resolve and verify SMTP connectivity/configuration in the target testing environment.
2. Ensure production error handling does not expose stack traces or detailed internal errors.

3. Confirm and document supported methods for individual staff-user resources.
4. Continue testing other API areas and authorization boundaries as access and scope expand.
5. Retest any corrected behavior and record the new results against the affected test IDs.

9. Conclusion

No confirmed security vulnerabilities were identified during the API security and validation testing. The tested authentication, authorization, input-validation and account-enumeration controls behaved as expected.

One password-reset reliability/configuration issue was identified: an unavailable SMTP service caused an HTTP 500 response for a valid password-reset request. In addition, an informational observation was recorded where the individual staff-user endpoint returned HTTP 405 for GET requests. Neither was classified as a confirmed security vulnerability.

FINAL STATUS
NO CONFIRMED SECURITY VULNERABILITIES IDENTIFIED

Prepared by: Daniel Opeyemi Olutoyinbo
Role: Cybersecurity Intern
Project: Markelo API Security Testing